

HASH FUNCTIONS, HMAC

Hash Functions

- A hash function is a function whose output is shorter than its input

$$H : \{0, 1\}^{< 2^{64}} \rightarrow \{0, 1\}^n$$

H	n
MD4	128
MD5	128
SHA-1	160
SHA-256	256
SHA-3	224, 256, 384, 512

- Hash functions are used as building blocks for encryption, MACs and digital signatures, blockchains, as key derivation functions, to store passwords, etc.

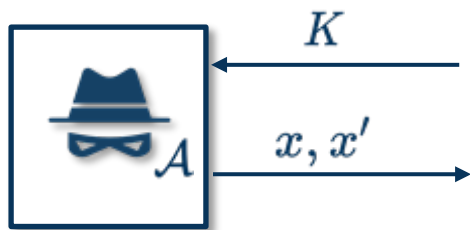
Security of Hash Functions

- What security properties a good hash function H should have?
- A collision is a pair M_1, M_2 from the domain s.t. $M_1 \neq M_2$ and $H(M_1) = H(M_2)$
- If the domain is larger than 2^n then there must be collisions (by pigeonhole principle)
- Collision-resistance, informally: should be infeasible to find a collision
- How to formalize this goal?
- Need to consider families of hash functions

Collision Resistance (CR)

Let $H : \{0, 1\}^k \times \mathcal{D} \rightarrow \{0, 1\}^n$ be a function family.

Pick K at random from $\{0, 1\}^k$



The *cr* advantage of $\mathcal{A}$, $\text{Adv}_H^{\text{cr}}(\mathcal{A})$, is defined as $\Pr[H(K, x) = H(K, x')]$

where $x \neq x'$

CR security is defined the usual way.

Example

Let $H : \{0, 1\}^k \times \{0, 1\}^{256} \rightarrow \{0, 1\}^{128}$ be defined by

$$H_K(x) = H_K(x[1]x[2]) = \text{AES}_K(x[1]) \oplus \text{AES}_K(x[2])$$

Is H collision resistant?

Can you design an adversary $\mathcal{A}$



Such that $H_K(x_1) = H_K(x_2)$?

Merkle-Damgård Transform

- Used by many hash functions, including MD, SHA-1 and SHA-2 families

Given: Compression function $h : \{0, 1\}^k \times \{0, 1\}^{b+n} \rightarrow \{0, 1\}^n$.

Build: Hash function $H : \{0, 1\}^k \times \mathcal{D} \rightarrow \{0, 1\}^n$.

Algorithm $H_K(M)$

$m \leftarrow \|M\|_b$; $M[m+1] \leftarrow \langle M \rangle$; $V[0] \leftarrow 0^n$

For $i = 1, \dots, m+1$ do $V[i] \leftarrow h_K(M[i] \| V[i-1])$

Return $V[m+1]$



MD Transform and CR Security

- ◆ **Claim:** If h is CR, then H , when built from h using MD, is CR too.
- ◆ But are the compression functions of practical hashes CR?

Birthday Attacks

- ◆ A hash function is regular if every range point has the same number of pre-images
- ◆ If a hash function is regular then the birthday attack finds a collision in about $2^{n/2}$ trials
- ◆ If it is not regular, the attack may succeed sooner
- ◆ It seems that the practical hashes are “close to regular”
- ◆ So there should not be attacks much faster than birthday attacks

Cryptanalytic Attacks on Hash Functions

Hash	When	Time
MD4	1995	seconds
MD5	2005, 2006	1 minute
SHA-1	2005	2^{69}
SHA-1	2017	$2^{63.1}$

February 23, 2017: SHAttered Attack

- ◆ Researchers from Google and CWI, Amsterdam found the first collision for SHA-1! Two PDF files with the same hash.
- ◆ Took roughly $2^{63.1}$ SHA-1 evaluations
- ◆ About 100,000 times faster than brute forcing with a birthday attack (2^{80})
- ◆ The attack required the equivalent processing power as 6,500 years of single-CPU computations and 110 years of single-GPU computations

2 PDFs, Same SHA-1 Hash

SHattered
The first concrete collision attack against SHA-1
<https://shattered.io>

CWI
Marc Stevens
Pierre Karpman

Google
Elie Bursztein
Ange Albertini
Yanik Markov

SHattered
The first concrete collision attack against SHA-1
<https://shattered.io>

CWI
Marc Stevens
Pierre Karpman

Google
Elie Bursztein
Ange Albertini
Yanik Markov

```
— sha1sum *.pdf
8762cf7f55934b34d179ae6a4c80cadccbb7f0a 1.pdf
8762cf7f55934b34d179ae6a4c80cadccbb7f0a 2.pdf
— /tmp/sha1
— sha256sum *.pdf
bb787a73e37352f92383abe7e2902936d1059ad9f1ba6daaa9c1e58ee6970d0 1.pdf
4488775d29bdef7993367d541064dbdda50d383f89f0aa13a6ff2e0894ba5ff 2.pdf
```

0.64G 8-11h

PDF 1 | PDF 2

original image from <https://shattered.io>

SHA-3

- ◆ National Institute for Standards and Technology (NIST) held a world-wide competition to develop a new hash function standard
- ◆ 2012: Winner announced: Keccak
- ◆ 2015: SHA-3 is standardized
- ◆ SHA-3 is conjectured to be collision-resistant

One-Wayness of Hash Functions

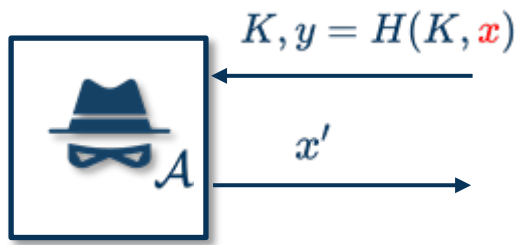
- Informally, a hash function is one-way if, given y and K , it is infeasible to find a pre-image of y under H_K .

Formal Definition of One-Wayness

Let $H : \{0, 1\}^k \times \mathcal{D} \rightarrow \{0, 1\}^n$ be a function family.

Pick K at random from $\{0, 1\}^k$

Pick x at random from $\mathcal{D}$



The ow advantage of $\mathcal{A}$, $\text{Adv}_H^{\text{ow}}(\mathcal{A})$, is defined as $\Pr[H(K, x') = y]$

OW security is defined the usual way

CR vs OW

- ◆ Does collision-resistance imply one-wayness?
- ◆ Does one-wayness imply collision-resistance?

CR vs OW

- ◆ Does collision-resistance imply one-wayness?
 - Not in general. Why?
 - Yes, for functions which compress
- ◆ Does one-wayness imply collision-resistance?
 - No. Why? Can you think of a hash which is one-way, but not collision-resistant?

Hash-based MACs

◆ $H(K\|M)?$

◆ $H(M\|K)?$

◆ $H(K\|M\|K)?$

HMAC, Hash-based MAC

Suppose $H : \mathcal{D} \rightarrow \{0, 1\}^n$ is the hash function. HMAC has a n -bit key K .

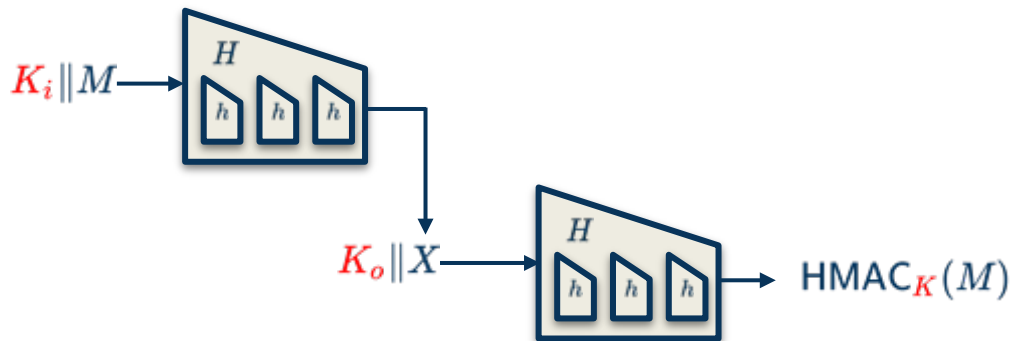
Let $B \geq n/8$ denote the byte-length of a message block ($B = 64$ for MD5, SHA-1, SHA-256, SHA-512)

Let $K_o = \text{opad} \oplus K \parallel 0^{8B-n}$ and $K_i = \text{ipad} \oplus K \parallel 0^{8B-n}$

where $\text{opad} = 5C$ and $\text{ipad} = 36$ in HEX, repeating B times respectively

Then

$$\text{HMAC}_K(M) = H(K_o \parallel H(K_i \parallel M))$$



HMAC

- ◆ Easy to implement
- ◆ Fast in software
- ◆ Usage:
 - as a MAC for message authentication
 - as a PRF for key derivation
- ◆ One of the most widely standardized and used cryptographic constructs: SSL/TLS, SSH, IPSec, FIPS 198, IEEE 802.11, IEEE 802.11b, ...

HMAC Security

- ◆ **Theorem:** HMAC is a PRF assuming the compression function H is a PRF.